

VULNERABILITY ASSESSMENT REPORT

Read-Only Security Assessment

Target: testfire.net (Altoro Mutual Demo Application)

Future Interns – Cyber Security Task 1 (2026)

Prepared By: G.Snehal

Assessment Date : 31 August 2026

Assessment Type : Passive / Read-Only

2. Executive Summary

This report presents a limited, read-only vulnerability assessment of the publicly accessible Altoro Mutual demonstration website hosted at testfire.net. The assessment focused on passive network exposure, HTTP response headers, cookie security attributes, HTTPS redirection, and browser-visible security controls. No exploitation, brute force, denial-of-service, login bypass, or other intrusive testing was performed.

The assessment identified several security-hardening gaps in the tested main document response. The session cookie was observed with HttpOnly and Secure protections, while an explicit SameSite attribute was not visible in the browser evidence. The tested response also did not show Strict-Transport-Security, X-Frame-Options/CSP frame-ancestors, or X-Content-Type-Options.

HTTP-to-HTTPS behavior was checked as a positive control. Nmap showed 80/tcp, 443/tcp, and 8080/tcp as open from the assessment point; many other common ports were filtered. Open ports are not automatically vulnerabilities and should be reviewed against the intended architecture.

OWASP ZAP passive scanning was not completed because Windows Security blocked the downloaded ZAP package as potentially unwanted software. No ZAP findings are claimed in this report.

3. Scope & Authorization

3.1 Scope

- Target: <https://testfire.net/>
- Application: Altoro Mutual / Testfire public demonstration application.
- Testing mode: Read-only, passive and configuration-focused checks.
- In-scope activities: public page review, Nmap top-port exposure check, browser response-header inspection, cookie-attribute inspection, and HTTP-to-HTTPS behavior check.

3.2 Out of Scope / Not Performed

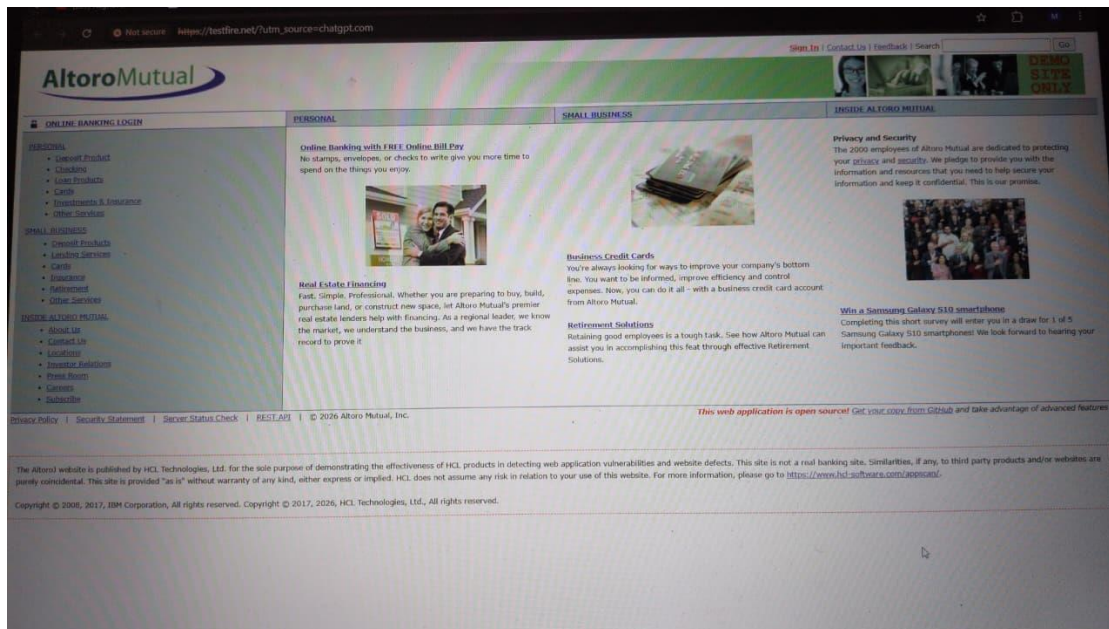
- Exploitation of vulnerabilities.
- Authentication bypass or credential attacks.
- Brute-force testing.
- Denial-of-service or stress testing.
- Active/attack-mode vulnerability scanning.
- Modification of website data or application state.

3.3 Authorization & Ethical Boundary

The assessment was deliberately restricted to non-destructive checks appropriate to the internship's read-only scope. The selected target is a security-training/demo application rather than a production banking service.

4. Website Tested

The selected target was testfire.net, presenting the Altoro Mutual demonstration banking application. The site was reachable during testing and was used only for passive observation.



01-target-website.jpeg — Target website / scope selection

5. Tools & Methodology

Tool / Method	Purpose	Use in Assessment
Nmap 7.991	Basic network exposure	Top 20 common TCP ports with - Pn
Chrome DevTools	HTTP response headers and cookies	Main document response inspected
Browser navigation	HTTPS behavior	HTTP → HTTPS behavior checked
OWASP ZAP	Passive web security scanning	Not completed; blocked by Windows Security

Methodology principle: observe and document only. No active scanning or attack payloads were used.

6. Findings

ID / Finding	Risk	Evidence-based summary
F-01 Session Cookie Missing Explicit SameSite Attribute	Medium	JSESSIONID showed HttpOnly and Secure indicators, while SameSite appeared blank in the browser evidence. This is a security-hardening gap; practical CSRF impact depends on application behavior and other request protections. Evidence: E-04 / 04-cookie-security.jpeg

F-02 HSTS Header Not Observed	Low	Strict-Transport-Security was not visible in the tested main document response evidence. Evidence: E-07 / 07-hsts-response-header.jpeg
F-03 Clickjacking Protection Not Observed	Low	X-Frame-Options and a CSP frame-ancestors directive were not visible in the tested response evidence. Evidence: E-08 / 08-clickjacking-headers.jpeg
F-04 X-Content-Type-Options Not Observed	Low	X-Content-Type-Options was not visible in the tested response evidence. Evidence: E-09 / 09-content-type-options.jpeg
F-05 Server Technology Banner Disclosure	Informational	The response exposed Server: Apache-Coyote/1.1. This provides fingerprinting information but does not by itself demonstrate compromise. Evidence: E-03 / 03-security-headers.png

7. Risk Summary

Risk Level	Count	Findings
Medium	1	F-01 – SameSite attribute
Low	3	F-02 – HSTS; F-03 – Clickjacking; F-04 – X-Content-Type-Options
Informational	1	F-05 – Server banner disclosure

Risk ratings are qualitative and reflect the limited evidence available from passive checks. They are not proof of exploitability.

8. Detailed Vulnerability Explanations

F-01 – Session Cookie Missing Explicit SameSite Attribute

Risk: Medium

Observation: Chrome DevTools showed a JSESSIONID cookie with HttpOnly and Secure indicators; SameSite appeared blank.

Impact: An explicit SameSite policy can reduce unwanted cross-site cookie transmission. Practical CSRF impact depends on state-changing endpoints and other request protections.

Recommendation: Set an appropriate SameSite policy, commonly Lax where compatible, or Strict where application requirements allow. Validate legitimate cross-site flows before deployment.

F-02 – HSTS Header Not Observed

Risk: Low

Observation: Strict-Transport-Security was not present in the tested main document response evidence.

Impact: The response does not explicitly instruct the browser to use HSTS for future connections.

Recommendation: Configure HSTS after confirming HTTPS is consistently available; use an appropriate max-age and add includeSubDomains only when all subdomains are ready.

F-03 – Clickjacking Protection Not Observed

Risk: Low

Observation: X-Frame-Options and a CSP frame-ancestors directive were not observed.

Impact: The tested response lacks an explicit response-level anti-framing control.

Recommendation: Use an appropriate CSP frame-ancestors directive and/or X-Frame-Options where legacy compatibility is required.

F-04 – X-Content-Type-Options Not Observed

Risk: Low

Observation: X-Content-Type-Options was not observed.

Impact: Without nosniff, browsers may have greater latitude to MIME-sniff certain resources.

Recommendation: Add X-Content-Type-Options: nosniff and verify legitimate resources continue to load correctly.

F-05 – Server Technology Banner Disclosure

Risk: Informational

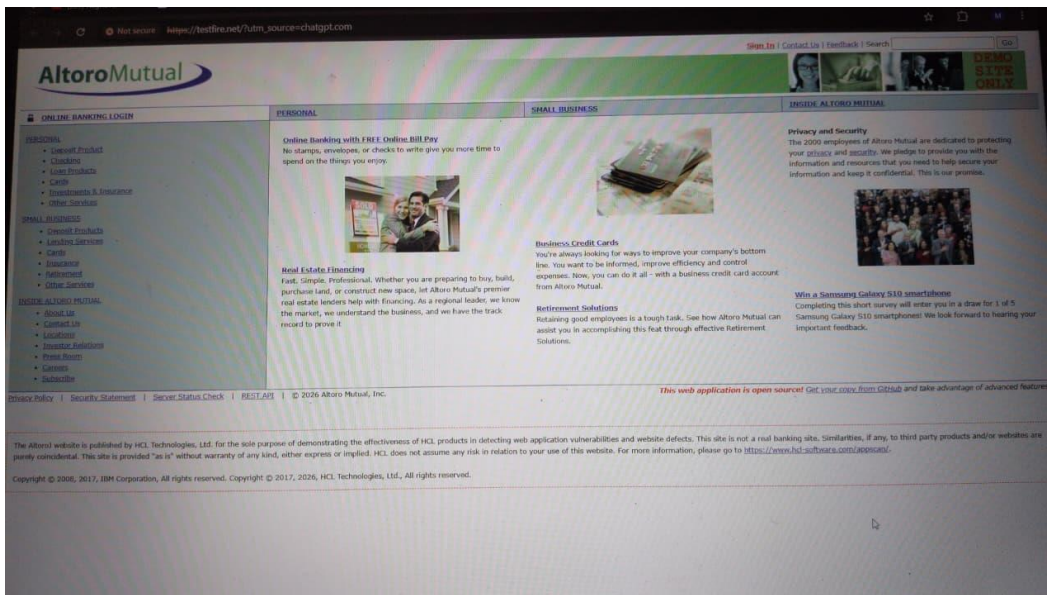
Observation: Server: Apache-Coyote/1.1 was exposed.

Impact: This can provide useful fingerprinting information but does not by itself demonstrate compromise.

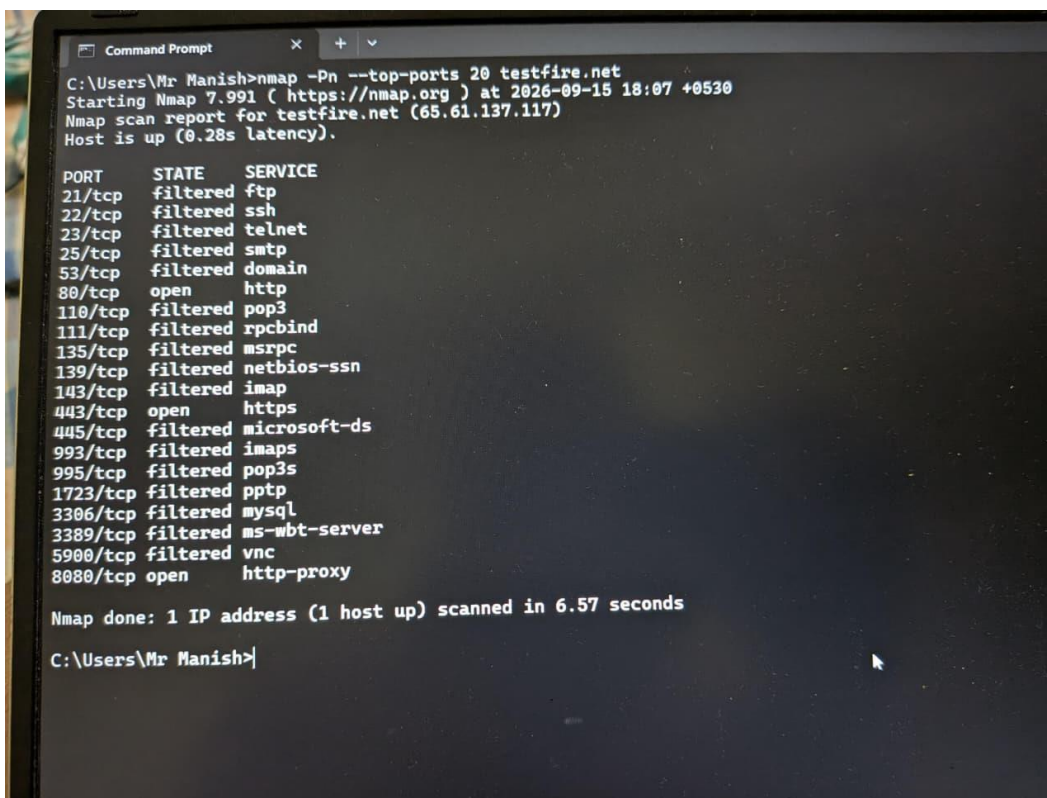
Recommendation: Minimize unnecessary server-banner detail where practical and keep underlying components patched.

9. Evidence Screenshots

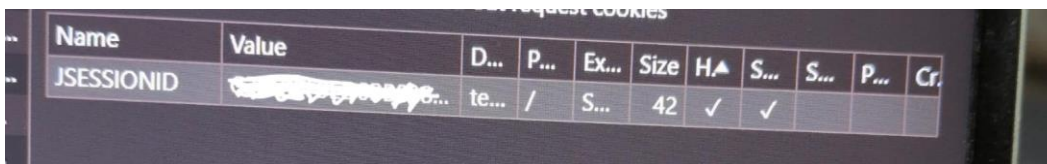
All evidence supplied for this final report is arranged in assessment order. Cookie values were redacted before inclusion. Do not upload an unredacted JSESSIONID or any other live session token to GitHub.

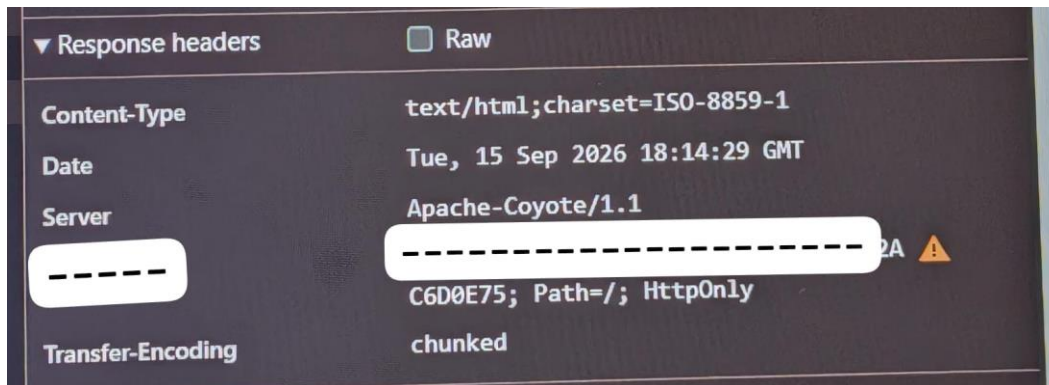


01-target-website.jpeg — Target website / scope selection



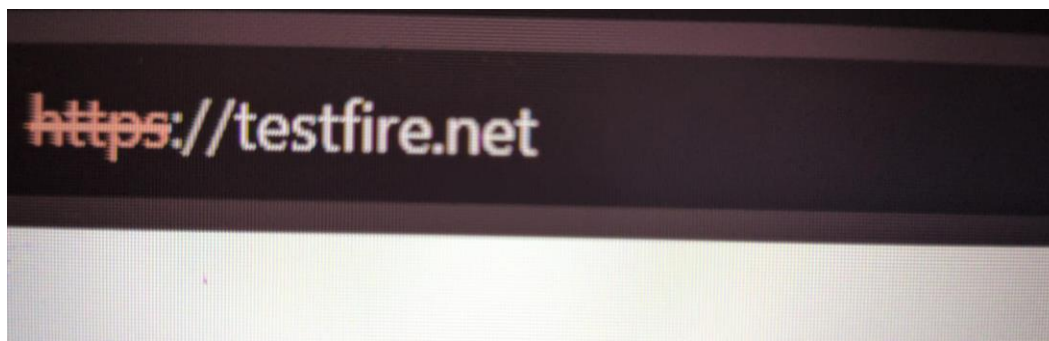
02-nmap-result.jpeg — Nmap top-20 TCP port exposure result





03-security-headers-redacted.png — Initial browser response-header inspection (cookie value redacted)

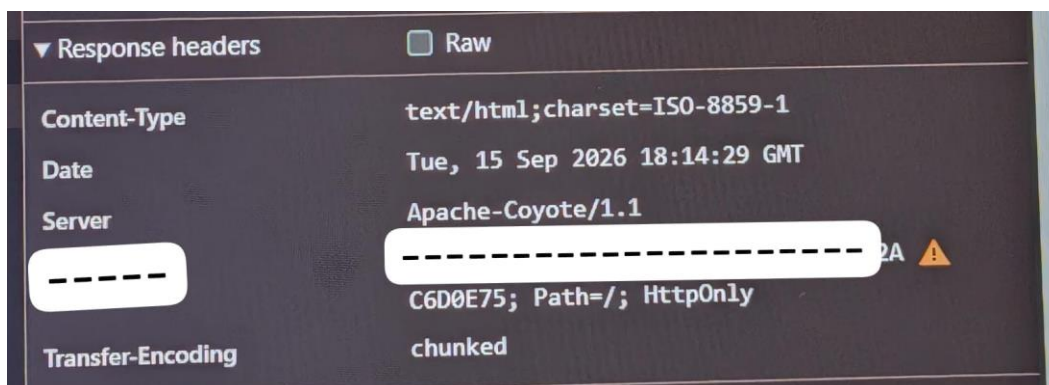
04-cookie-security.jpeg — Cookie security attributes; value redacted



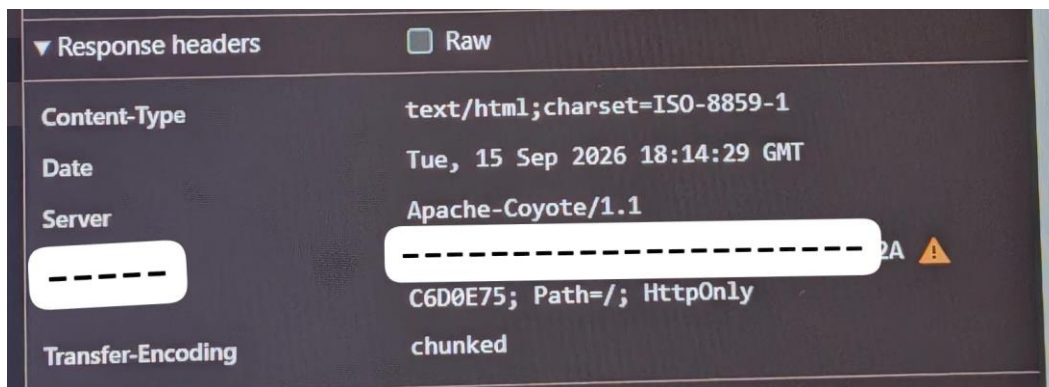
05-http-to-https-before.jpeg — HTTP request before HTTPS redirect



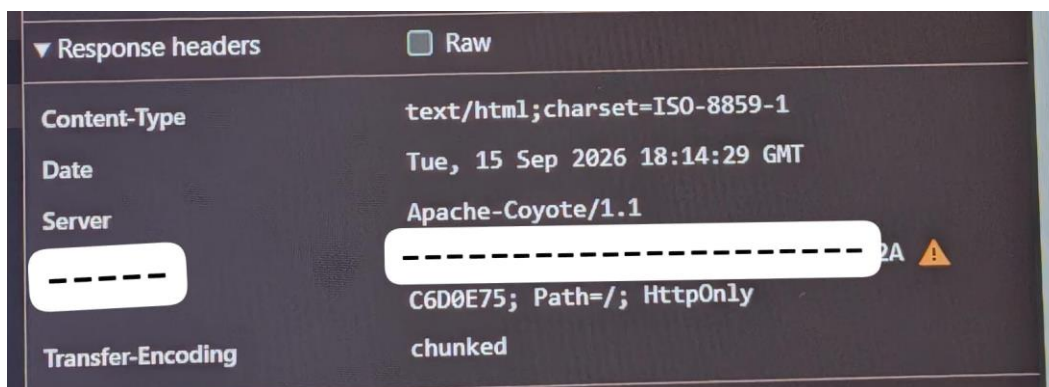
06-http-to-https-after.jpeg — HTTPS result after redirect



07-hsts-response-header.jpeg — Response-header evidence for HSTS check



08-clickjacking-headers.jpeg — Response-header evidence for clickjacking protection check



09-content-type-options.jpeg — Response-header evidence for X-Content-Type-Options check

10. Remediation Recommendations

- Configure an explicit SameSite policy for session cookies after validating application compatibility.
- Enable HSTS with an appropriate max-age; use includeSubDomains only after confirming readiness.
- Add anti-clickjacking protection using CSP frame-ancestors and/or X-Frame-Options where appropriate.
- Add X-Content-Type-Options: nosniff.
- Reduce unnecessary server-banner detail where practical.
- Review public exposure of port 8080 and restrict it if it is not intentionally public.
- Maintain routine patching and configuration review of web server and application components.

11. Conclusion

The read-only assessment identified several configuration and security-hardening opportunities while confirming useful controls such as HTTPS redirection and protected session-cookie attributes (HttpOnly and Secure). Findings should be prioritized according to application architecture and business impact. Because testing was intentionally passive, exploitability was not tested.

OWASP ZAP was not used because Windows Security blocked the downloaded ZAP package. This limitation is explicitly recorded so the report does not misrepresent tool usage.

12. Appendix / Evidence Reference

Evidence ID	File	Purpose
E-01	01-target-website.jpeg	Target website / scope selection

E-02	02-nmap-result.jpeg	Nmap top-20 TCP port exposure result
E-03	03-security-headers.png	Initial browser response-header inspection
E-04	04-cookie-security.jpeg	Cookie security attributes; value redacted
E-05	05-http-to-https-before.jpeg	HTTP request before HTTPS redirect
E-06	06-http-to-https-after.jpeg	HTTPS result after redirect
E-07	07-hsts-response-header.jpeg	Response-header evidence for HSTS check
E-08	08-clickjacking-headers.jpeg	Response-header evidence for clickjacking protection check
E-09	09-content-type-options.jpeg	Response-header evidence for X-Content-Type-Options check

Submission checklist: Report PDF, Evidence folder, README, and public GitHub repository. Before publishing evidence, confirm that no live session-token values are visible.